

Progetto Finale

Hardening del Firewall Windows contro Attività di Ricognizione (Nmap)

Obiettivo dell'Esercizio

In questo laboratorio ho applicato le policy di sicurezza di base su Windows. Ho effettuato una scansione guidata dalla macchina Linux (Kali) per simulare le prime fasi di un attacco di Information Gathering, configurato il Firewall di Windows per bloccare questa minaccia, e verificato l'efficacia della difesa analizzando i log nativi del sistema operativo.

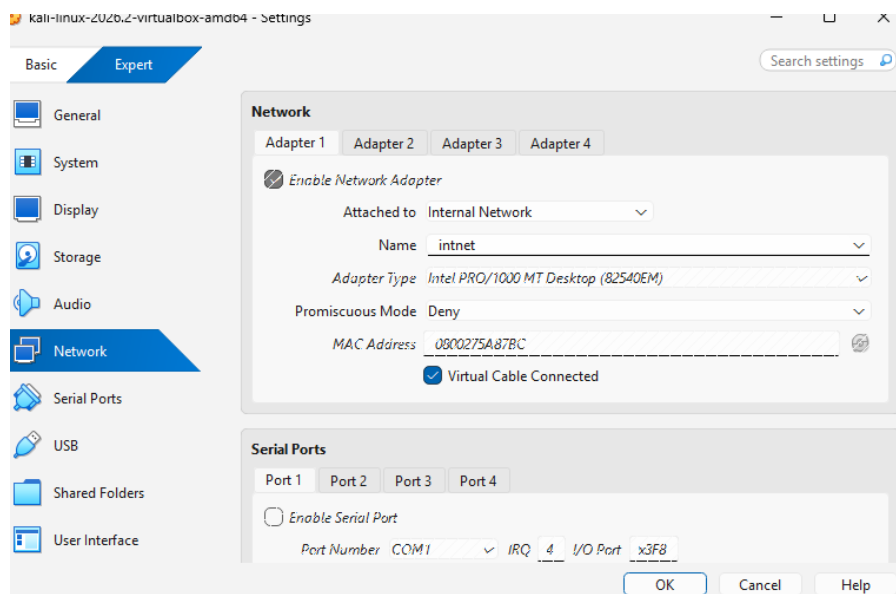
Ambiente di Laboratorio

Ruolo	Sistema operativo	Indirizzo IP
Macchina Attaccante	Kali Linux	192.168.50.100
Macchina Difensore	Windows 10 (Metasploitable)	192.168.50.102

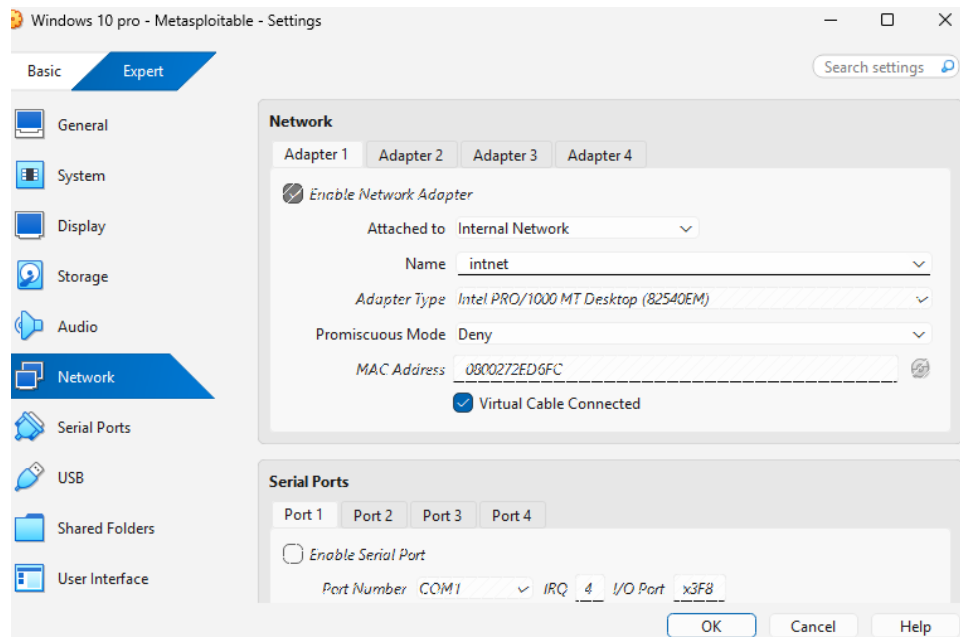
Entrambe le macchine virtuali sono state collegate alla stessa rete interna VirtualBox ("intnet"), per simulare una rete locale isolata.

Fase 1 — Verifica della Connettività di Base

Prima di tutto ho configurato l'adattatore di rete di entrambe le macchine virtuali sulla stessa rete interna (intnet), per garantire che potessero comunicare tra loro.



Configurazione rete della VM Kali Linux: adattatore su rete interna "intnet"



Configurazione rete della VM Windows 10: stessa rete interna "intnet"

Ho poi verificato l'indirizzo IP assegnato a Kali con il comando `ip a`, confermando l'indirizzo 192.168.50.100.

```
kali-linux-2026.2-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default
    qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.100/24 brd 192.168.50.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::91cb:17bf:fa7f:816f/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
(kali@kali)-[~]
$
```

Output del comando "ip a" su Kali Linux

Infine ho verificato la connettività dalla macchina Windows verso Kali con il comando ping, confermando 0% di pacchetti persi:

```
ca Prompt dei comandi
Configurazione IP di Windows

Scheda Ethernet Ethernet:

  Suffisso DNS specifico per connessione:
  Indirizzo IPv4. . . . . : 192.168.50.102
  Subnet mask . . . . . : 255.255.255.0
  Gateway predefinito . . . . . : 192.168.50.1

Scheda Tunnel isatap.{92D61F82-1D19-45C9-B7CF-2E5AF2D63627}:

  Stato supporto. . . . . : Supporto disconnesso
  Suffisso DNS specifico per connessione:

C:\Users\user>ping 192.168.50.100

Esecuzione di Ping 192.168.50.100 con 32 byte di dati:
Risposta da 192.168.50.100: byte=32 durata=1ms TTL=64
Risposta da 192.168.50.100: byte=32 durata=1ms TTL=64
Risposta da 192.168.50.100: byte=32 durata=1ms TTL=64
Risposta da 192.168.50.100: byte=32 durata=1ms TTL=64

Statistiche Ping per 192.168.50.100:
  Pacchetti: Trasmessi = 4, Ricevuti = 4,
  Persi = 0 (0% persi),
  Tempo approssimativo percorsi andata/ritorno in millisecondi:
    Minimo = 1ms, Massimo = 1ms, Medio = 1ms

C:\Users\user>
```

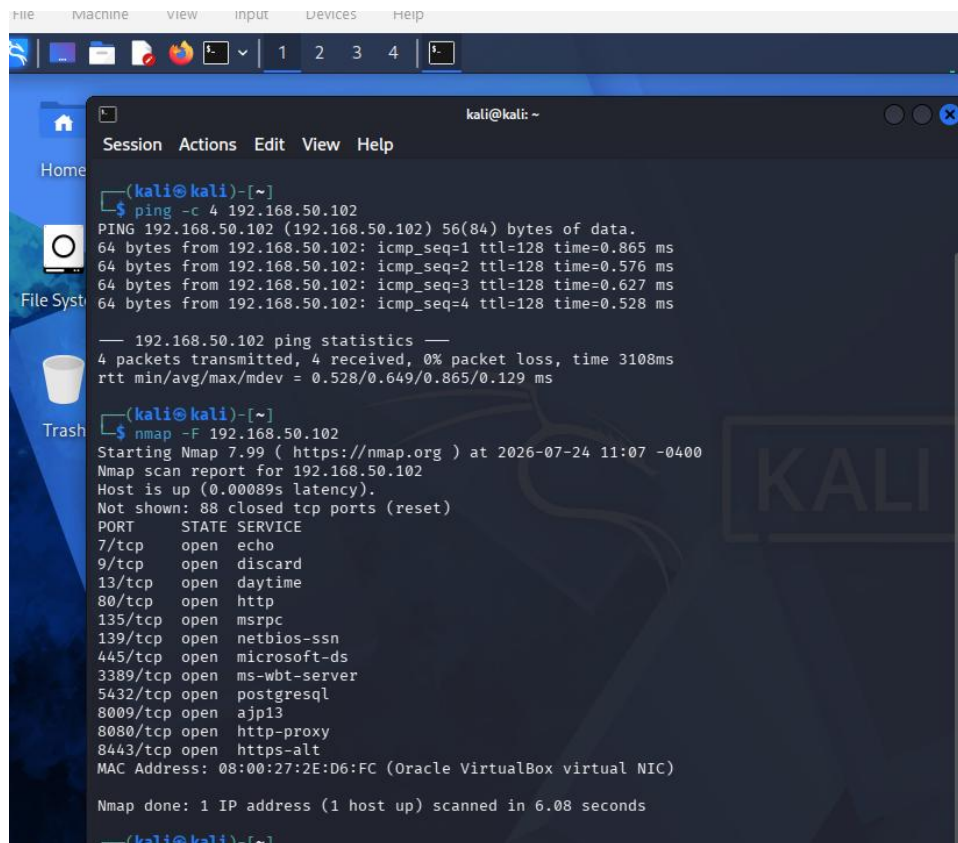
Ping da Windows verso Kali (192.168.50.100): connessione confermata

Risultato: le due macchine comunicano correttamente sulla stessa rete virtuale, condizione necessaria per procedere con la scansione.

Fase 2 — Ricognizione con Nmap (Information Gathering)

Dalla macchina Kali ho lanciato una scansione veloce delle porte del sistema Windows con il comando:

```
ping -c 4 192.168.50.102 & nmap -F 192.168.50.102
```



```
file machine view input Devices Help
1 2 3 4

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ ping -c 4 192.168.50.102
PING 192.168.50.102 (192.168.50.102) 56(84) bytes of data:
64 bytes from 192.168.50.102: icmp_seq=1 ttl=128 time=0.865 ms
64 bytes from 192.168.50.102: icmp_seq=2 ttl=128 time=0.576 ms
64 bytes from 192.168.50.102: icmp_seq=3 ttl=128 time=0.627 ms
64 bytes from 192.168.50.102: icmp_seq=4 ttl=128 time=0.528 ms

— 192.168.50.102 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3108ms
rtt min/avg/max/mdev = 0.528/0.649/0.865/0.129 ms

(kali@kali)-[~]
$ nmap -F 192.168.50.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 11:07 -0400
Nmap scan report for 192.168.50.102
Host is up (0.00089s latency).
Not shown: 88 closed tcp ports (reset)
PORT      STATE SERVICE
7/tcp     open  echo
9/tcp     open  discard
13/tcp    open  daytime
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5432/tcp  open  postgresql
8009/tcp  open  ajp13
8080/tcp  open  http-proxy
8443/tcp  open  https-alt
MAC Address: 08:00:27:2E:D6:FC (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 6.08 seconds

(kali@kali)-[~]
```

Scansione Nmap iniziale: porte aperte rilevate su Windows

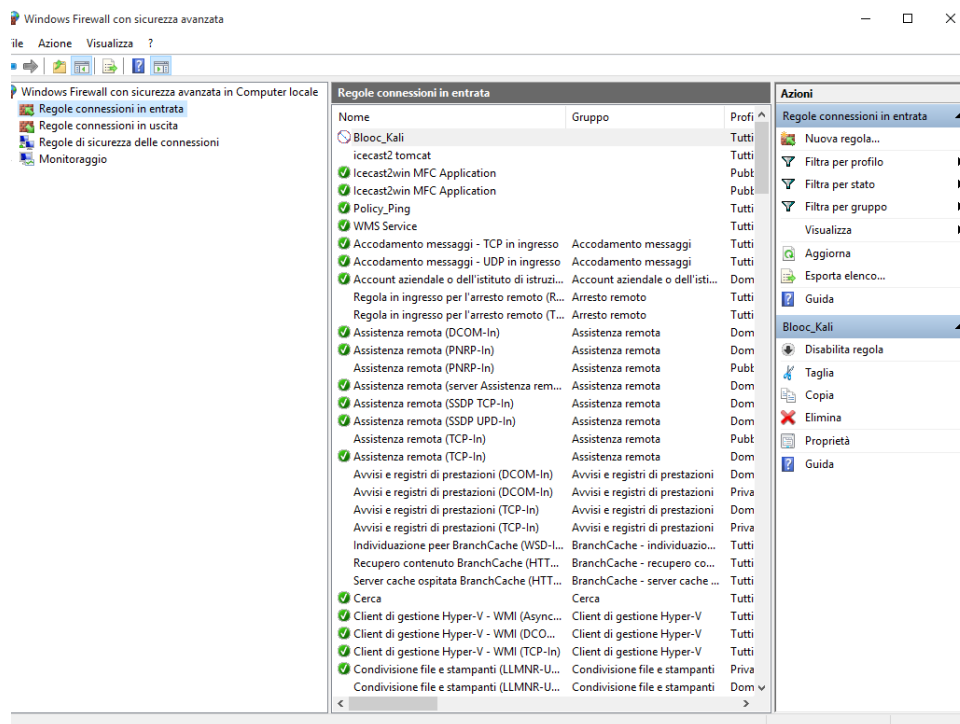
Analisi: la scansione ha rilevato numerose porte aperte e accessibili, tra cui alcune particolarmente sensibili dal punto di vista della sicurezza:

1. 135/tcp, 139/tcp — msrpc / netbios-ssn: usate per enumerazione di rete
2. 445/tcp — microsoft-ds (SMB): servizio spesso target di exploit noti (es. EternalBlue)
3. 3389/tcp — RDP (ms-wbt-server): se esposto, permette tentativi di accesso remoto
4. Altre porte aperte non standard (7, 9, 13, 80, 5432, 8009, 8080, 8443), tipiche di una macchina volutamente vulnerabile ("metasploitable")

Questo rappresenta esattamente ciò che un attaccante osserverebbe nella fase di ricognizione, prima di scegliere quale vulnerabilità sfruttare.

La Difesa: Hardening del Firewall

Per bloccare l'attaccante ho aperto "Windows Defender Firewall con sicurezza avanzata" sulla macchina Windows e creato una nuova regola personalizzata in ingresso (Regole in entrata), configurata per bloccare qualsiasi connessione proveniente esclusivamente dall'indirizzo IP di Kali (192.168.50.100). Ho assegnato alla regola il nome "Blocco_Kali".



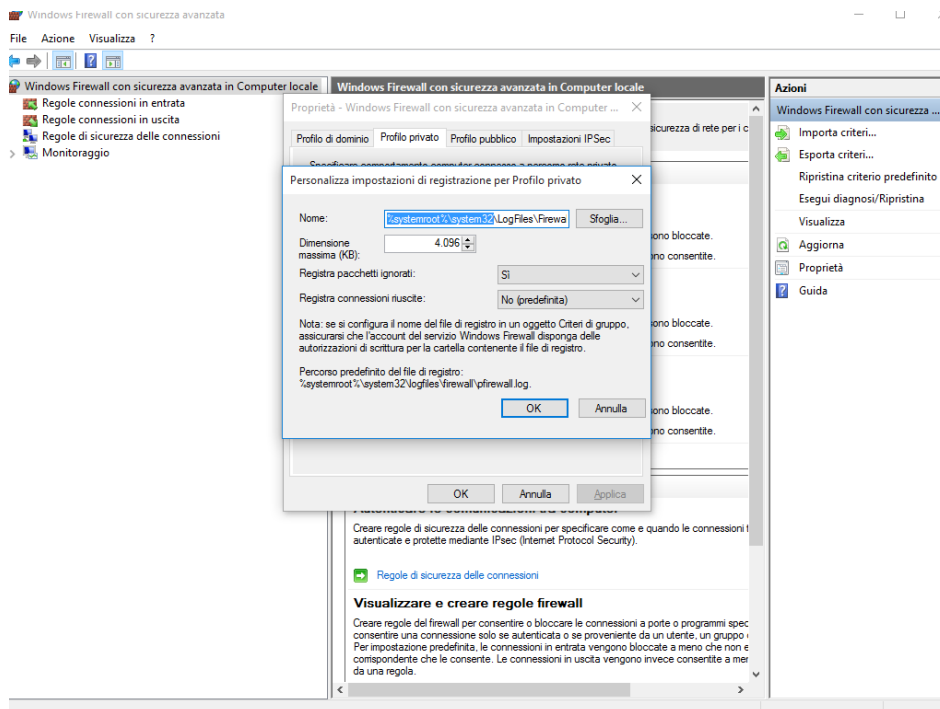
Elenco delle regole in entrata: la regola "Blocco_Kali" risulta attiva (icona verde)

La regola è visibile nell'elenco delle Regole connessioni in entrata, attiva e correttamente denominata.

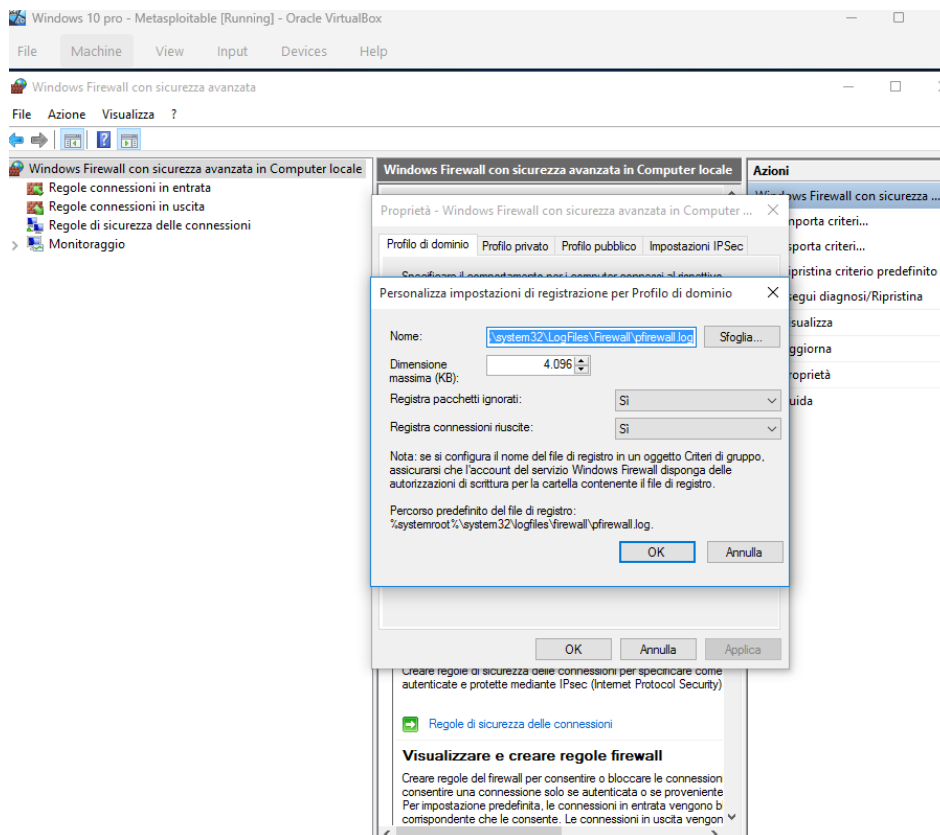
Abilitazione dei Log e Verifica Finale

Per poter analizzare successivamente il traffico bloccato, ho abilitato la registrazione dei pacchetti scartati ("Log dropped packets" = Sì) nelle proprietà del firewall, sia per il profilo Privato che per il profilo di Dominio, mantenendo il percorso di log predefinito

%systemroot%\system32\LogFiles\Firewall\pfirewall.log.

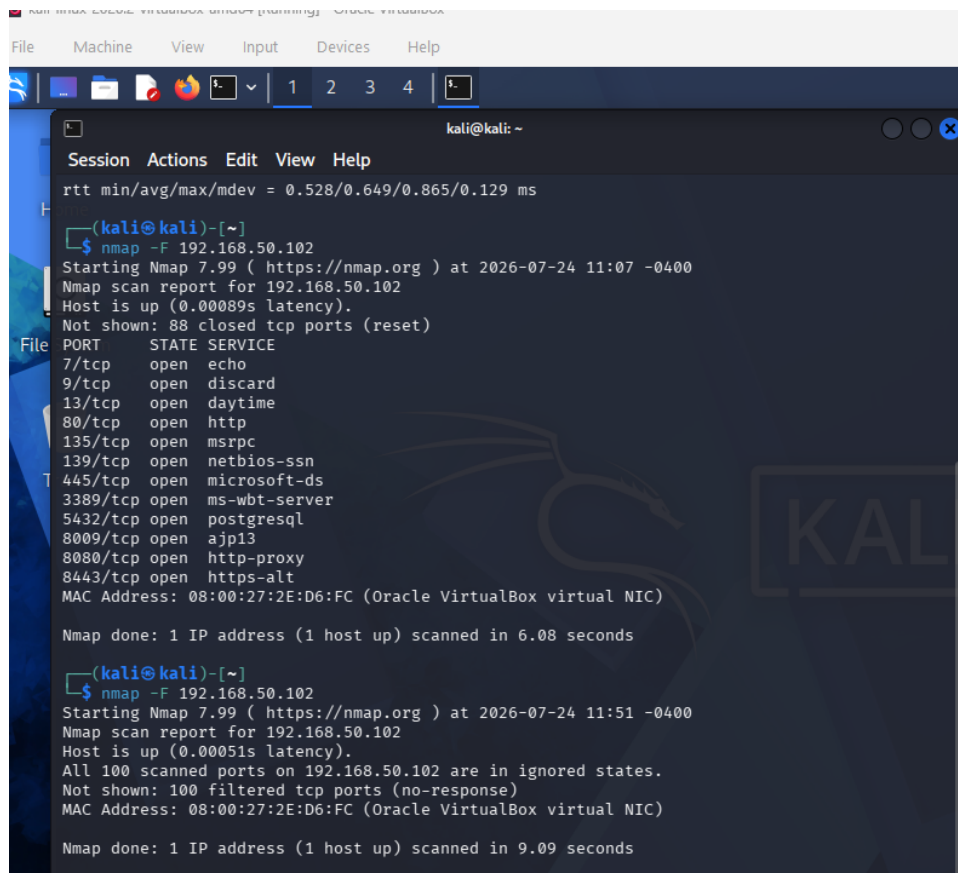


Registrazione pacchetti ignorati abilitata (Profilo privato)



Registrazione pacchetti ignorati abilitata (Profilo di dominio)

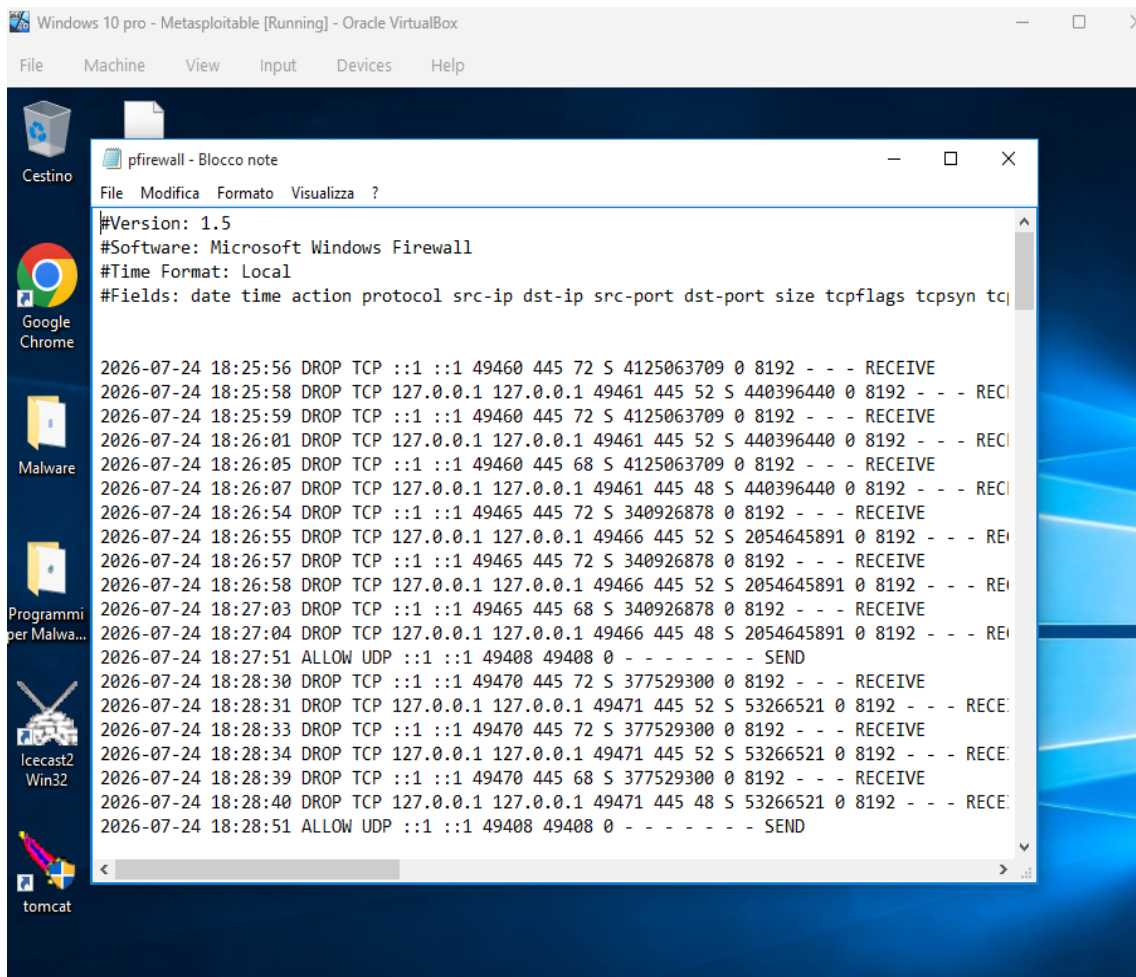
Ho quindi ripetuto la scansione Nmap dalla macchina Kali verso Windows, per verificare l'efficacia della regola di blocco appena creata:



```
kali@kali: ~  
Session Actions Edit View Help  
rtt min/avg/max/mdev = 0.528/0.649/0.865/0.129 ms  
$ nmap -F 192.168.50.102  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 11:07 -0400  
Nmap scan report for 192.168.50.102  
Host is up (0.00089s latency).  
Not shown: 88 closed tcp ports (reset)  
PORT      STATE SERVICE  
7/tcp     open  echo  
9/tcp     open  discard  
13/tcp    open  daytime  
80/tcp    open  http  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
3389/tcp  open  ms-wbt-server  
5432/tcp  open  postgresql  
8009/tcp  open  ajp13  
8080/tcp  open  http-proxy  
8443/tcp  open  https-alt  
MAC Address: 08:00:27:2E:D6:FC (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 6.08 seconds  
  
$ nmap -F 192.168.50.102  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 11:51 -0400  
Nmap scan report for 192.168.50.102  
Host is up (0.00051s latency).  
All 100 scanned ports on 192.168.50.102 are in ignored states.  
Not shown: 100 filtered tcp ports (no-response)  
MAC Address: 08:00:27:2E:D6:FC (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 9.09 seconds
```

Confronto tra la scansione iniziale (porte open) e quella successiva al blocco (porte filtered)

Risultato: mentre la prima scansione (ore 11:07) mostrava 12 porte aperte in circa 6 secondi, la seconda scansione (ore 11:51), eseguita dopo l'attivazione della regola firewall, mostra tutte le 100 porte scansionate in stato "filtered" (nessuna risposta), con un tempo di esecuzione più che raddoppiato (9,09 secondi) — effetto tipico del filtraggio, poiché Nmap deve attendere il timeout su ogni porta invece di ricevere una risposta immediata.



Riepilogo dei Risultati

Indicatore	Prima del blocco	Dopo il blocco
Stato porte (nmap -F)	12 porte open	100/100 porte filtered
Tempo di scansione	6,08 secondi	9,09 secondi
Connettività ICMP (ping)	Attiva	Non testata dopo il blocco

Conclusioni

L'esercizio ha dimostrato in modo pratico l'intero ciclo di un incidente di sicurezza base: ricognizione (information gathering) da parte di un potenziale attaccante, individuazione dei servizi esposti, e risposta difensiva tramite una regola firewall mirata. La verifica finale con Nmap conferma che la regola "Blocco_Kali" ha effettivamente reso irraggiungibili tutti i servizi precedentemente esposti dall'indirizzo IP dell'attaccante, e l'abilitazione del logging permette di tracciare e analizzare ogni tentativo di connessione bloccato per scopi di auditing e incident response.